

Assignment 1 - Secure Software Systems - INTE2667

1 Part One: Four Real-World Security Attacks

1.1 Human Error – Clorox / Cognizant Ransomware Incident

The major consumer goods business Clorox experienced a major ransomware attack in August 2023 which disrupted its operational activities. The security incident at Cognizant began at a third-party IT service provider, when a helpless employee failed to verify an identity during a help-desk personnel/task request. The attacker was able to impersonate an authorized employee to convince the help-desk agent to reset multi-factor authentication (MFA) credentials and bypass the control. The attackers gained access to the systems and the systems administrator then disabled the security capability and escalated the privileges, before deploying the ransomware requiring Clorox to shut down parts of its manufacturing and order-processing systems. The company estimated damages at \$380 million, including \$49 million in immediate remediation costs. The incident demonstrates how social engineering through help-desk impersonation can bypass strong security systems when human verification systems do not function correctly. The incident demonstrates the requirement for enhanced identity verification standards together with ongoing employee training and mandatory approval procedures for critical account modifications (Fadilpašić, 2025).

1.2 System Configuration Error – TalentHook Azure Misconfiguration

In 2022, an incident took place where a recruiting company based in Canada called TalentHook, exposed approximately 26 million resumes due to a misconfigured Microsoft Azure Blob Storage container. The storage bucket stored a lot of sensitive personal data such as full names, email addresses, phone numbers, complete educational history, and complete employment history. The information was entirely publicly accessible and did not require authentication. The open storage container was discovered by security researchers and we do not know how long this container was publicly accessible, and any and all information there could be used against people for mass identity theft and/or targeted phishing attacks. TalentHook's exfiltration of personal data is reflected in not applying access control, which is a situation that occurs naturally and easily in a cloud environment; as cloud vendors often place functionality above security with the default configurations often never changed or applied. This incident is a prime example of how an innocent misconfiguration could result in a complete data breach; along with illustrating the need for cloud automation and check security, implementing proper practices within cloud storage, and conducting audits to avoid accidental exposure of sensitive data (Woollacott, 2025).

1.3 Flawed Development Process – 2017 Equifax Breach

The 2017 Equifax incident is one of the most significant data breaches to occur within history as it impacted 147 million Americans by exposing their personal details including Social Security Numbers, birth dates, and credit cards. The breached process was further swollen by myriad security failures, the most prominent of which is Equifax's failure to patch a public vulnerability (CVE-2017-5638) in Apache Struts, a well-known open source web application framework. CVE-2017-5638 was a vulnerability which allowed for remote code execution published and patched in March 2017, however Equifax had failed to patch the systems. After exploiting the vulnerability for the first time in May 2017, the attackers had unauthorized access for 76 days due to the company's inability to monitor systems effectively. Furthermore, after the fact the investigation also found significant security issues, such as unencrypted information, default administrative credentials, and horrifically poor network segmentation. After the fact, the company eventually agreed to a \$1.4 billion settlement, but this incident exposed crippling weakness in patch management, vulnerability assessment, and incident response. It demonstrates that even a large enterprise such as Equifax is susceptible to potentially disastrous breaches due to neglected development and remediation practices (Epic Org, n.d.) (*Equifax Data Breach: A Look at How It Happened*, 2025).

1.4 COTS Vulnerability – 2023 MOVEit Software Breach

In May 2023, CL0P, a ransomware group, exploited a zero-day vulnerability (CVE-2023-34362) in MOVEit Transfer, a commercial file-transfer utility from Progress Software. The vulnerability in MOVEit Transfer was significant because it provided complete control, without having to authenticate counter to permissions, for arbitrary commands, and potential access to sensitive files hosted on a corporate server. The breach affected over 2,700 organizations - including government agencies, healthcare companies, and financial services - and exposed the sensitive data of over 93 million individuals. Organizations breached included Shell, British Airways, the U.S. Department of Energy and dozens of colleges and universities. This breach illustrated the potential for a single, exploitable vulnerability in a COTS product, widely used and across multiple industries, to present a real world threat at scale. Progress Software advanced an emergency patch shortly after the breach was made known to the public. Unfortunately, many organizations had already been victimized and exploited prior to the emergency patch release. Breaches like this reveal all of the latent risk in using third party software, and not having continuous vulnerability scanning, timely patch management, and network segmentation planning to control lateral movement in the event of exploitation (National Cyber Security Center, 2023) (Hadrian, 2025) (Dosumu, 2025).

1.5 Summary of identified attacks

Attack Example	Type of Attack	Source	Impact	Vulnerability Known/Unknown?	Additional Notes
Clorox / Cognizant Ransomware (2023)	Human Error (Help-desk Social Engineering)	(Fadilpašić, 2025).	- \$380M in damages (including \$49M remediation costs) - Manufacturing disruptions - Data exfiltration - Reputational harm	Known (Social engineering attacks are well-documented, but MFA bypass techniques evolve)	Attackers exploited lack of 'secondary verification in IT support processes.
TalentHook Azure Misconfiguration (2022)	System Configuration Error (Unsecured Cloud Storage)	(Woollacott, 2025)	- 26M resumes exposed - Personal data (names, emails, employment history) leaked - Increased phishing/identity fraud risks	Known (Misconfigured cloud storage is a recurring issue; AWS/Azure provide warnings)	No malware or hacking required—data was publicly accessible due to oversight.
2017 Equifax Breach	Flawed Development Process (Unpatched Software)	(Epic Org, n.d.) (<i>Equifax Data Breach: A Look at How It Happened</i> , 2025)	- 147M records stolen (SSNs, credit cards) - \$1.4B in settlements - Regulatory scrutiny - Long-term identity theft risks	Known (CVE-2017-5638 was patched 2 months prior; Equifax failed to update)	Other failures: default passwords, poor segmentation, unencrypted data.
2023 MOVEit Breach	COTS Product Vulnerability (Zero-Day Exploit)	(National Cyber Security Center, 2023) (Hadrian, 2025) (Dosumu, 2025)	- 2,700+ organizations compromised - 93M individuals affected - CL0P ransomware extortion - Government, healthcare, and financial sector impacts	Unknown (Zero-day at time of exploitation; patch released after attacks began)	Progress Software's MOVEit was widely trusted, highlighting supply chain risks.

2 Part Two – Potential of Occurrence and Remedies

2.1 Human Error – Clorox / Cognizant Ransomware Incident

The Clorox fiasco showcases just how a human can circumvent technical security, especially where identity verification protocols failed. In the Electronic Voting Platform (EVP), a similar vulnerability could occur in the A+EC help-desk or the administrative support subsystem. For example, a malicious actor could impersonate an AEC official or an IT staff member through some phone or email interaction, and trick a support agent by convincing them to reset the privileged credentials for the administrator account which would allow the threat actor to access:

- Voter registration databases
- Modify the list of candidates
- Disable critical security tools or procedures, like intrusion detection systems before election day

Given that the EVP includes both on-site terminals and remote administrative access, the help-desk is a high-risk entry point, if sufficient multi-channel verification is not in place. In summary, it is imperative that identity verification procedures are put into place. Including, but not limited to:

- Multi-step and separate approvals for any changes or actions taken regarding privileged accounts.
- Secure communication channels, e.g., encrypted VOIP platform or authenticated ticketing system for all requests to help-desk or systems administrator.
- Callback to a pre-registered internal number for all sensitive requests and actions.

David (2018) emphasizes that each organization should make social engineering awareness a priority. An ongoing training program should be a requirement for all staff. Realistic phishing / impersonation will reinforce best practice as they on-boarding and continually throughout their careers with the organization. Routine audits of all help-desk interaction can help an organization identify procedural missteps before they are exploited.

[Source: (Fadilpašić, 2025)]

2.2 System Configuration Error – TalentHook Azure Misconfiguration

The TalentHook case demonstrates how one cloud storage bucket misconfiguration can lead to an enormous data leak. In the context of EVP, this could happen if cloud-hosted details (such as encrypted backups of ballots; exports of voter rolls; a file with candidates' details; etc.) were hosted in misconfigured Azure Blob Storage or AWS S3 buckets. These files can become publicly accessible, and attackers can harvest them and target misinformation campaigns or voter's suppression strategies pre-election. The EVP has to manage a good deal of sensitive personally identifiable information (PII); thus a single incorrectly configured storage instance could jeopardize the confidentiality, and integrity of the whole electoral process.

To prevent the risks mentioned above, the EVP's cloud infrastructure should adopt a strict cloud configuration management program. All storage endpoints should be private-by-default, any

access should be role based via RBAC to a specific identity, sensitive files should be encrypted at rest and in transit. The EVP would benefit from automated compliance checks, such as Microsoft Defender for Cloud, or AWS Config, ideally running continuous scans for misconfiguration or policy violations triggering alerts, or blocking public access until manually verified by a security officer. A quarterly audit of configurations should also be compulsory to ensure compliance with the Australian Cyber Security Centre (ACSC) Cloud Security Guidance.

[Source: (Staff, 2025)]

2.3 Flawed Development Process – 2017 Equifax Breach

The Equifax breach illustrates the disastrous impact of neglecting to patch known vulnerabilities. In the EVP, this risk very directly relates to the web application layer and the voter registration/voting interface subsystem. If the platform is using open-source components - authentication libraries, encryption libraries, voting calculation libraries, etc. - and they disclose a vulnerability that has not been patched in a timely manner, attackers can exploit this vulnerability to manipulate ballots, leak voter data, or take down the system at critical times during the election (e.g., when the platform is experiencing maximum traffic). Because the EVP is distributed (with up to 40,000 terminals making up the overall platform), this could increase attack surface area - allowing for attackers to spread a zero-day worm across the distributed devices.

Mitigation involves establishing appropriate (hopefully automated) vulnerability management processes adhered to within the DevSecOps pipeline. This process includes automated dependency scanning (e.g., Snyk, Dependabot), checking CVE feeds daily, and ensuring SLAs are established for critical patches (for example, 24 hours after the vulnerability has been published for a critical severity CVE). In addition, code changes are required to undergo static and dynamic security testing to validate risk levels of vulnerabilities before they can be deployed. All changes are also to be completed with the use of a staging area configured to be identical to production, to test possible impacts of updates. In addition, the EVP should embed secure coding standards defined by OWASP ASVS to ensure software development practices limit the number of exploitable flaws from the beginning.

[Source: (*Equifax Data Breach: A Look at How It Happened*, 2025)]

2.4 COTS Vulnerability – 2023 MOVEit Software Breach

The MOVEit incident illustrates the potential for vulnerabilities in third-party software to have a ripple effect across thousands of organizations. The EVP will likely be using COTS components for secure file transfer, results aggregation, or encrypted communication between polling stations and central servers. If one of these COTS products had a zero-day vulnerability in it, attackers could compromise the EVP without ever interacting with the EVP custom code. For example, an attacker who exploited a file transfer service used to send the vote counts aggregated would be able to manipulate the vote totals that would be sent to the central tallying server.

To address this concern, the EVP's procurement and maintenance policy for third-party software will need to require a thorough risk assessment of a vendor ahead of usage, which would include evaluating each vendor's history of security patches and security vulnerabilities, reviewing the quality of the code, and assessing their vulnerability disclosure timeline and process. COTS components should be run in sandboxed or containered environments, protecting critical election systems, and limiting the ability to lateral moves across election systems. There should be a software bill of materials (SBOM) or documentation that can be maintained and updated to capture information about software dependencies used, and the ability to deploy emergency patches should be periodically testable from a simulated zero-day perspective.

[Source: (Dosumu, 2025)]

2.5 Summary Comments

The four vulnerabilities—human error, system misconfiguration, flawed development, and COTS exploitation—each pose a notable threat to the Electronic Voting Platform because of its distributed system, high-value data, and reliance on third-party components. The consequence of any breach is heightened by the requirement of public trust in elections; even the slightest breach may result in national disputes regarding the legitimacy of elections. The most favorable overall security posture for the EVP would resemble defense-in-depth, a layered defense that includes policy compliance and enforcement, continual monitoring and logging, technical controls, and regular maintenance of patches/configuration management. Also, red-team pen-testing should be standard before each election cycle as it would ensure that exploitable weaknesses, vulnerabilities, and flaws were discovered and preferably remediated.

3 Part Three: Security Requirements Using SQUARE (15 points)

1. **Authentication:** All election officials who carry out administrative functions will use multi-factor authentication, which includes hardware issued tokens and biometric verification, and if there is 15 minutes of inactivity, the session will expire. *(Confidentiality/Accountability)*
2. **Data Integrity:** Ballot records will be cryptographically signed upon creation by using FIPS 140-3 validated modules and those signatures shall be able to be verified by an independent auditing system. *(Integrity)*
3. **Availability:** The online voting portal will have an availability of 99.99% during the voting window of 4 weeks, through the use of geographically load balanced DDoS mitigation strategies. *(Availability)*
4. **Non-repudiation:** Each vote cast will result in a digitally signed receipt with an anonymous voting token (not linked to the identity of the voter), that a voter can use to verify their ballot was included in the final vote count. *(Non-repudiation)*
5. **Anonymity:** The vote storage subsystem will cryptographically separate voter identification from ballot contents within 60 minutes of voting using NIST approved separation techniques. *(Anonymity)*
6. **Audit:** The system will create immutable logs and auditable logs of all activities performed within the election management remit, with a retention policy of 7 years and WORM (write once read many policy). *(Accountability)*
7. **Input Validation:** Any web interfaces will sanitize all incoming inputs using OWASP ESAPI filters prior to processing. All malformed requests will be rejected and security staff will be automatically notified. *(Integrity)*
8. **Patch Management:** All COTS components shall be patched within 72 hours of a critical security patch being made available to the community, and all patches will be tested in an isolated environment prior to production deployment. *(Integrity / Availability)*
9. **Physical Security:** An inclement tamper evident enclosure will be used for the voting premise terminal and system. The enclosure will alert active monitors to shut down the system if an attempt of physical tampering occurs. *(Integrity)*
10. **Access Control:** Role based access control will operate least privilege and will separate voter registration, ballot processing, and results compiling functions. *(Confidentiality)*
11. **Backup:** Encrypted backups of election related data will be made daily, during the election period, and will be stored offline in three different geo-locations. *(Availability)*

12. **Incident Response:** The system will have the ability to detect and contain security incidents within 15 minutes of occurring and all common attack scenarios will have pre-defined playbooks. (*Availability*)
13. **Cryptography:** All sensitive data in transit, will use TLS 1.3 and PFS. All sensitive data at rest, will use AES-256 encryption, and its keys will be managed by HSM. (*Confidentiality*).
14. **Voter Verification:** Voters will have a mechanism to verify their ballot was counted (without revealing their voters choice) through means of an anonymous receipt system for 30 days after election day. (*Non-repudiation*).
15. **Testing:** Independent penetration testing will occur on a biannual basis. Any high/critical finding will be remediated within 30 days, before the system is deployed to production. (*All security qualities*).

All requirements are based on SMART principles- they are specific to the voting system components, can be measured through defined metrics, will be achievable using presently available technology, are relevant to the field of electoral security and are time bound with dates.

4 References

- Dosumu, R. (2025, February). *MOVEit Data Breach: A Case Study in Zero-Day Exploits and Organizational Cybersecurity Preparedness*. Research Gate. Retrieved August 14, 2025, from https://www.researchgate.net/publication/388993135_MOVEit_Data_Breach_A_Case_Study_in_Zero-Day_Exploits_and_Organizational_Cybersecurity_Preparedness
- Epic Org. (n.d.). *EPIC - Equifax Data Breach*. EPIC. Retrieved August 14, 2025, from <https://archive.epic.org/privacy/data-breach/equifax/>
- Equifax data breach: A look at how it happened*. (2025). Mozilla. Retrieved August 14, 2025, from <https://www.mozilla.org/en-US/products/monitor/equifax-data-breach/>
- Fadilpašić, S. (2025, July 24). *Clorox sues Cognizant for "giving away" passwords which led to major breach*. TechRadar. Retrieved August 14, 2025, from <https://www.techradar.com/pro/security/clorox-sues-cognizant-for-giving-away-passwords-which-led-to-major-breach?>
- Hadrian. (2025). *MOVEit Breach: Timeline of the Largest Hack of 2023*. Hadrian. <https://hadrian.io/blog/moveit-cyberattacks-timeline-of-the-largest-hack-of-2023>
- National Cyber Security Center. (2023, June 7). *MOVEit vulnerability and data extortion incident - NCSC.GOV.UK*. National Cyber Security Centre. Retrieved August 14, 2025, from <https://www.ncsc.gov.uk/information/moveit-vulnerability>
- Staff, S. (2025, July 7). *TalentHook inadvertently leaks millions of job seekers' data*. SC Media. Retrieved 2025, from <https://www.scworld.com/brief/talenthook-inadvertently-leaks-millions-of-job-seekers-data>
- Woollacott, E. (2025, July 9). *26 million CVs were exposed when a recruiting software firm left a misconfigured Azure container open – cybersecurity experts warn it's an easy mistake that's becoming far too common*. IT PRO. Retrieved August 10, 2025, from <https://www.itpro.com/security/data-breaches/26-million-cvs-were-exposed-when-a-recruiting-software-firm-left-a-misconfigured-azure-container-open-cybersecurity-experts-warn-its-an-easy-mistake-thats-becoming-far-too-common?>